RELEASE READINESS ASSESSMENT

Taekworld

An external review of the production web surface across performance, security, accessibility, infrastructure, and content.

CLIENT	AUDITOR	METHOD	ACCESS
Taekworld	Aigenix	3-track parallel review	External only · no source

Today's agenda

Walk through the release readiness assessment, then discuss the MSP partner proposal and next steps.

PART 01 · ASSESSMENT

1. Method & scope
2. Overall verdict
3. Score interpretation
4. Category breakdown
   Performance · Security · Accessibility · Infrastructure · Content
5. Release readiness by use case
6. MSP partner brief · Caylent

PART 02 · REMEDIATION

7. Four critical blockers
8. Warnings & verification cadence
9. Projected score trajectory
10. Phase 2 roadmap & precedent
11. COPPA exposure & legal next step
12. Appendix · what we cannot assess

Method & scope

Three parallel review tracks against the public production surface. No source code access; everything below is externally verifiable via HTTP.

TRACK 01

Frontend

Rendered HTML, meta tags, semantic structure, accessibility attributes, viewport, zoom policy.

TRACK 02

Backend & infra

TLS, response headers, CORS, redirects, DNS, CDN, caching, edge regions, email auth.

TRACK 03

Performance

Page weight, font loading, CSS/JS delivery, image pipeline, TTFB, compression, HTTP/2.

Five scored categories · weighted average · verdict against five release scenarios.

OVERALL SCORE

38/100

■ NOT RELEASE-READY

Critical blockers must be resolved before any public launch. Infrastructure is strong; the rendered web surface is not.

WEIGHTED BY CATEGORY

Infrastructure	85	19%	16.2
Content & structure	40	12%	5.0
Security	30	25%	7.5
Performance	25	25%	6.3
Accessibility	15	19%	2.8
Weighted total		100%	**37.8**

Where 38 lands on the scale

0–19	20–39 · YOU	40–59	60–79	80–100
Foundational	**Not ready**	**Beta at best**	**Soft-launch**	**Release-ready**
Major rework required.	Critical blockers present.	Significant gaps in core areas.	Known issues acceptable for limited audience.	Minor polish only.

PART 01

Category breakdown

Five categories. Each scored out of 100 from externally verifiable signals.

CATEGORY 01

Performance

25/100

■ POOR

733 font preloads alone could make the page unusable on mobile networks. Total page weight with fonts may exceed 15 MB.

CHECK	PTS
Page weight (excl. fonts) 1.9 MB — heavy	5 / 15
Font loading 733 preloads · ~14 MB waste	1 / 26
CSS delivery 923 KB render-blocking	3 / 15
JS delivery 717 KB · 110 KB polyfills	5 / 15
Image optimization No next/image · no lazy loading	0 / 15
TTFB 256 ms — good	8 / 10
Compression & HTTP/2 Brotli · HTTP/2 enabled	9 / 10

CATEGORY 02

Security

30/100

■ POOR

Blocker for payments. Stripe without CSP is a PCI compliance risk; Twilio Voice without Permissions-Policy may silently fail.

CHECK	PTS
HTTPS enforced 308 redirect · HSTS set	15 / 15
Content-Security-Policy Missing	1 / 26
X-Frame-Options Missing	0 / 10
X-Content-Type-Options Missing	0 / 10
Referrer-Policy Missing	0 / 10
Permissions-Policy Missing — critical for Twilio mic	0 / 10
CORS policy * — overly permissive	5 / 10
TLS 1.3 & cert validity Valid until 2026-06-29	15 / 15

CATEGORY 03

Accessibility

15 /100

■ FAILING

Low score partially due to CSR bailout hiding all content from static analysis — but SSR output is what matters for assistive tech on initial load.

CHECK	PTS
Zoom / scale allowed `user-scalable=no · WCAG violation`	1 / 26
Semantic HTML `0 elements in SSR`	1 / 26
ARIA attributes `0 detected`	0 / 15
Alt text on images `0 images in SSR output`	0 / 15
Color contrast `Cannot verify (CSR)`	5 / 10
Keyboard navigation `Cannot verify (CSR)`	5 / 10
Language attribute `lang="en" set`	5 / 5

CATEGORY 04

Infrastructure

85/100

■ RELEASE-READY

The strongest area of the audit. Vercel + Cloudflare + Let's Encrypt + ISR caching is production-grade. Two gaps: DMARC and single-region.

CHECK	PTS
Hosting platform Vercel — production-grade	15 / 15
CDN Vercel Edge Network	10 / 10
DNS Cloudflare — fast, reliable	10 / 10
TLS setup TLS 1.3 · auto-renew Let's Encrypt	10 / 10
HTTP redirects HTTP→HTTPS · www→non-www	10 / 10
Caching & edge ISR 300s · iad1	19 / 26
Email · MX / SPF Google Workspace · DMARC missing	7 / 15
Multi-region Single region detected	5 / 10

CATEGORY 05

Content & structure

40/100

■ BELOW AVERAGE

i18n is correctly configured across three locales, but most subpages redirect to root and all content is hidden behind client-side rendering.

CHECK	PTS
i18n setup 3 locales · hreflang correct	15 / 15
Navigation structure Sparse · /services, /pricing redirect	6 / 26
Subpage depth /about, /contact exist · others redirect	5 / 15
Content richness in SSR Blank — all in CSR	1 / 26
URL structure Clean locale-based routing	10 / 15
404 handling Catch-all masks true 404s	5 / 15

Release readiness by use case

Current score · 38 · against five launch scenarios.

SCENARIO	NEEDED	CURRENT	READY?
Internal demo / investor pitch	30+	38	POSSIBLE
Private beta · invited users only	50+	38	RISKY
Public soft-launch	60+	38	NO
Production launch with marketing	75+	38	NO
Enterprise / B2B sales	80+	38	NO

CANDIDATE MSP PARTNER

Caylent

AWS-native consulting firm, ~900 employees. Microsoft stack experience over 5–10 years. Top-tier AWS partner — engagement fees can be **offset by AWS funding**.

WHAT THEY DO FOR US

- **Initial assessment** — security, infra, architecture review
- **Architecture design** — target-state diagrams, AWS service selection
- **Detailed specs** — implementation-ready documents
- **Buildout & launch** — optional follow-on engagements
- **Migrations** — MS SQL → AWS RDS, data platforms via partners

Engagement · 2 weeks → 6+ months

OPEN QUESTION · COPPA SCOPE

Whether their audit covers a **legal & compliance technical review** — verifying UI and Firebase Security Rules against COPPA "School Consent" — is TBC on follow-up call. Core offering is architecture and infra, not legal opinion.

PRICING ENVELOPE

Initial assessment 1 principal architect · 2–4 weeks · PM 15–25% if complex	**$25K–$50K**
Team support · monthly ~30 hrs / week · resource pool · remediation or AI buildout	**$11K / mo**
CloudOps · 24/7 Scales with AWS footprint · post-migration only	**$25K / mo**

* **Implementation** billed separately. * **Legal consulting** separate engagement, not included.

AWS FUNDING MECHANIC

Free-tier AWS account → share account ID → AWS account manager attaches funding to offset Caylent fees.

NEXT STEPS ON OUR SIDE

1. Send NDA
2. Follow-up call: solution architect
3. Set up AWS account
4. Receive formal proposal

PART 02

Remediation guide

Four release blockers and a set of warnings — framed as specs for the dev team, with externally verifiable checks.

BLOCKER 01

883 · 733 · 14 MB

Font preload explosion

The next/font configuration is loading every unicode subset of M PLUS Rounded 1c, producing 883 @font-face declarations and 733 preload tags.

SPEC FOR DEV TEAM

01 Set `subsets: ['latin']` in next/font config; add latin-ext only if required.

02 Limit preloaded fonts to the 2–3 actually used on first render.

03 Load M PLUS Rounded 1c only on pages that need CJK, with `display: 'swap'`

04 Target: fewer than 10 preload tags; CSS under 100 KB.

VERIFICATION

```
# count preload tags on prod
curl -s https://taekworld.com \
  | grep -c 'rel="preload"'

# Target: < 10  (currently 733)
```

BLOCKER 02

BAILOUT_TO_CLIENT_SIDE_RENDERING

Client-side rendering bailout

A client-only API in the root layout — likely useSearchParams or usePathname outside Suspense — is forcing the entire page to render on the client. Initial HTML is blank.

SPEC FOR DEV TEAM

01 Audit `layout.tsx` for client-only hooks in client components.

02 Wrap any client-only logic in a `<Suspense>` boundary.

03 Move client-only hooks from layout to leaf page components.

04 Ensure semantic landmarks are present in server-rendered HTML.

VERIFICATION

```
# no bailout sentinel
curl -s https://taekworld.com \
  | grep -c 'BAILOUT_TO_CLIENT_SIDE_RENDERING'
# Target: 0  (currently 1)

# semantic landmarks in SSR
curl -s https://taekworld.com \
  | grep -coE '<header|<nav|<main|<h1'
# Target: > 0  (currently 0)
```

BLOCKER 03

5 of 6 · missing

Missing security headers

Only HSTS is set. Five critical headers are missing — a concern alongside Stripe payments and the Twilio Voice SDK.

HEADER	RECOMMENDED VALUE
Content-Security-Policy	default-src 'self'; script-src 'self' js.stripe.com; connect-src 'self' api.stripe.com *.firebaseio.com; frame-src js.stripe.com;
X-Frame-Options	DENY
X-Content-Type-Options	nosniff
Referrer-Policy	strict-origin-when-cross-origin
Permissions-Policy	camera=(), microphone=(self), geolocation=()

BLOCKER 04

WCAG 1.4.4

Pinch-to-zoom blocked

The viewport meta tag blocks pinch-to-zoom, violating WCAG 1.4.4 (Resize text). A hard accessibility failure that blocks low-vision users.

CURRENT

```
<meta name="viewport"
content="width=device-width,
         initial-scale=1,
         maximum-scale=1,
         user-scalable=no">
```

TARGET

```
<meta name="viewport"
content="width=device-width,
         initial-scale=1">
```

Remove `maximum-scale=1` and `user-scalable=no`. No other changes required.

VERIFICATION

```
# any scale-lock remains?
curl -s https://taekworld.com \
  | grep -o 'user-scalable=[^"]*'

# Target: no output
# currently user-scalable=no
```

Warning-level fixes

Not blockers, but meaningful score moves once the four blockers clear.

ISSUE	SPEC	VERIFICATION
WARN CORS *	Restrict `Access-Control-Allow-Origin` to specific domains (e.g. `https://taekworld.com`) or remove if not needed for public API.	`curl -sI url | grep access-control`
WARN CSS · 649 KB	Enable CSS code-splitting per page. Inline critical CSS for above-the-fold content. Consider Tailwind v4 `@layer` to prune unused rules.	`grep -c '<style>' > 0`
WARN Polyfills · 110 KB	Narrow `browserslist` to modern browsers only. Remove polyfills if targeting ES2020+.	`DevTools · bundle size`
WARN No next/image	Replace all `<img>` and CSS background images with `next/image` for automatic WebP/AVIF, srcset, and lazy loading.	`grep -c '_next/image' > 0`
WARN Catch-all 404	Add explicit routes that take priority over `[...slug]` so true 404s surface as 404s.	`curl -sI url/nope | grep 404`

AFTER EACH FIX DEPLOY

External health check

A single script, runnable from any shell, that re-verifies every fix from the outside. No repo access required.

RUN

After every deploy of a remediation PR.

READ

Each line should trend toward its target.

```
#!/usr/bin/env bash

SITE="https://taekworld.com"

echo "═══ Fonts ═══"
curl -s $SITE | grep -c 'rel="preload"'

echo "═══ CSR bailout ═══"
curl -s $SITE | grep -c 'BAILOUT'

echo "═══ Semantic HTML ═══"
curl -s $SITE | grep -coE '<header|<nav'

echo "═══ Security headers ═══"
curl -sI $SITE | grep -ciE 'csp|x-frame'

echo "═══ Zoom block ═══"
curl -s $SITE | grep -o 'user-scalable=[^"]*'
```

Projected score trajectory

A plausible path from today's 38 to production-ready, organized by fix batch. Each batch is scoped to what the dev team can land in a single sprint.

TODAY	+ FONTS + CSR	+ SECURITY HEADERS	+ A11Y + PERF POLISH
38 /100	~58 /100	~72 /100	~85 /100
NOT READY	BETA POSSIBLE	SOFT-LAUNCH POSSIBLE	PRODUCTION READY

Projections assume no regression elsewhere. Batches are ordered by blast-radius-per-effort.

AFTER REMEDIATION · AT SCALE

Architecture moves for 10K → 100K users

Ship Phase 1 on the current stack. Queue these migrations for when the user base breaks 10,000, and sequence them before 100,000.

Not launch blockers.
Scale blockers.

01 HIGH PRIORITY — cost · abuse

Video infrastructure

Vercel Blob → Cloudflare Stream

02 HIGH PRIORITY — reliability

Notification guarantee

Upstash QStash · serverless queue

03 MEDIUM PRIORITY — scale

B2B dashboard

PostgreSQL · geo-spatial sub-DB

Three migrations, ordered

For each, the driver, the swap, the trigger. Prepare design now; execute when the metric crosses its threshold.

01 HIGH

Video infrastructure

DRIVER

Egress costs compound. Videos can be scraped & re-hosted — no signed-URL + tokenization on Vercel Blob.

SWAP

Vercel Blob
→ Cloudflare Stream

GAINS

Signed playback URLs · per-video domain restriction · HLS/DASH · 70%+ cost reduction at scale.

TRIGGER

> 10K MAU · or · > 500 GB/mo egress

02 HIGH

Notification guarantee

DRIVER

Master-app push must be 100% reliable. Fire-and-forget from serverless functions drops on cold-starts & timeouts.

SWAP

Inline dispatch
→ Upstash QStash

GAINS

At-least-once delivery · retry with backoff · scheduled sends · per-device dead-lettering.

TRIGGER

first delivery-failure complaint · or · > 1K Masters

03 MEDIUM

B2B dashboard geo-search

DRIVER

Thousands of dojos, each with lat/long. "Nearest studio" and bbox queries degrade fast on non-spatial stores.

SWAP

Primary store
+ Postgres + PostGIS (Supabase)

GAINS

GIST-indexed ST_DWithin · sub-50ms "within 5km" at 10K+ rows · territory analytics.

TRIGGER

> 1K registered dojos · or · B2B launch

What the top edtech & video platforms actually run on

Four architectural moves that consistently show up in MasterClass, Coursera, ClassDojo, Duolingo, and Vercel Enterprise stacks. Each one directly maps to a Phase 2 decision.

T·1 VIDEO STREAMING SPECIALIZATION

File-on-CDN → HLS/DASH adaptive stream

Seen in **MasterClass · Coursera**
Stack `Mux · Cloudflare Stream`

- Adaptive bitrate — zero buffering at any speed
- Analytics track exact pause/skip per viewer
- Bandwidth ~70% cheaper than Blob at scale

T·2 SERVERLESS ASYNC QUEUES

Event-driven fanout with retries

Seen in **ClassDojo · Duolingo**
Stack `Inngest · Upstash QStash · AWS SQS`

- Push, payment hooks, email — never fire inline
- Auto-retry 5–10× on serverless cold-start drops
- Master-app signup alert loss rate → 0%

T·3 NOSQL + RDBMS HYBRID

Right tool per workload

Keep `Firebase` for auth · realtime chat
Add `Supabase / Postgres` for business data

- "Exclusive territory within 5mi" — 100ms SQL, not a scan
- "Top-converting dojos last 7d" — cheap aggregate

T·4 EDGE RENDERING · RSC MAXED

Decide at the edge, not the client

Seen in **Vercel Enterprise customers**
Stack `Next.js RSC · Edge Middleware`

- <0.5s TTFB across all 50 US states
- Trial/expired resolved before render — no flicker
- Paywall popups land in first paint

US LAUNCH BLOCKER

$50,120
per child · max fine

COPPA exposure

The **Children's Online Privacy Protection Act** requires verifiable parental consent before collecting any personal data from users under 13. FTC has issued nine-figure fines to YouTube and Epic Games for non-compliance.

WHAT WE COLLECT FROM MINORS TODAY

- **Student accounts** — name, email, password
- **Video telemetry** — device, IP, browser, watch time, completion rate, pause/seek events
- **Interaction traces** — click streams, menu access patterns

All three categories qualify as "personal information" under COPPA §312.2.

FINE MATH AT SCALE

100 students · one violation each	$5.0M
1,000 students · one violation each	$50.1M
YouTube · 2019 settlement	$170M

Strict liability. Intent is not a defense.

Resolution requires qualified legal counsel

COPPA exposure is flagged as a US-launch risk on the previous slide. The remediation path — consent model, data-minimization posture, contractual allocation of liability — is a **legal question, not an engineering one**. We do not provide legal advice.

STATUS

Issue documented

Risk surface and data categories enumerated on slide 23. Sufficient context for counsel to scope a review.

NOT IN SCOPE OF THIS ASSESSMENT

- Choice of consent mechanism
- Liability allocation between platform and dojo
- ToS · Privacy Policy drafting
- State-law overlays (CA AB-1394, NY SHIELD, etc.)

RECOMMENDED NEXT STEP

Engage privacy counsel before US onboarding

Brief to bring to counsel:

- Data inventory from slide 23
- Business model — B2B2C via dojos / Masters
- Target geography and ages of end users
- Whether FTC "school authorization" exception may apply

Engineering will implement whatever regime counsel defines.

What we cannot assess without source

Nine areas fall outside an external audit. For each, a concrete ask to unblock a deeper review.

AREA	WHY IT'S OPAQUE	ASK
Backend API security	ASP.NET Core server not externally mapped	Request Swagger URL or API base URL for separate audit.
Database security	PostgreSQL not externally reachable	Review EF Core query patterns and parameterization.
Auth flow integrity	JWT + Firebase dual-auth complexity is hidden	Request auth flow diagram; test token-refresh edge cases.
Stripe PCI compliance	Payment flow internals not visible	Verify Stripe Elements/Checkout used — never raw card input.
Flutter app quality	Separate binary · not web-analyzable	Request APK / IPA for mobile audit.
Code quality · tech debt	No repo access	Request read-only GitHub access or code walkthrough.
Test coverage	Not externally verifiable	Request test reports / CI pipeline overview.
Error monitoring	Cannot detect Sentry / Datadog / etc.	Confirm whether an APM is configured.
Environment separation	Cannot verify staging vs production isolation	Share deployment pipeline overview.